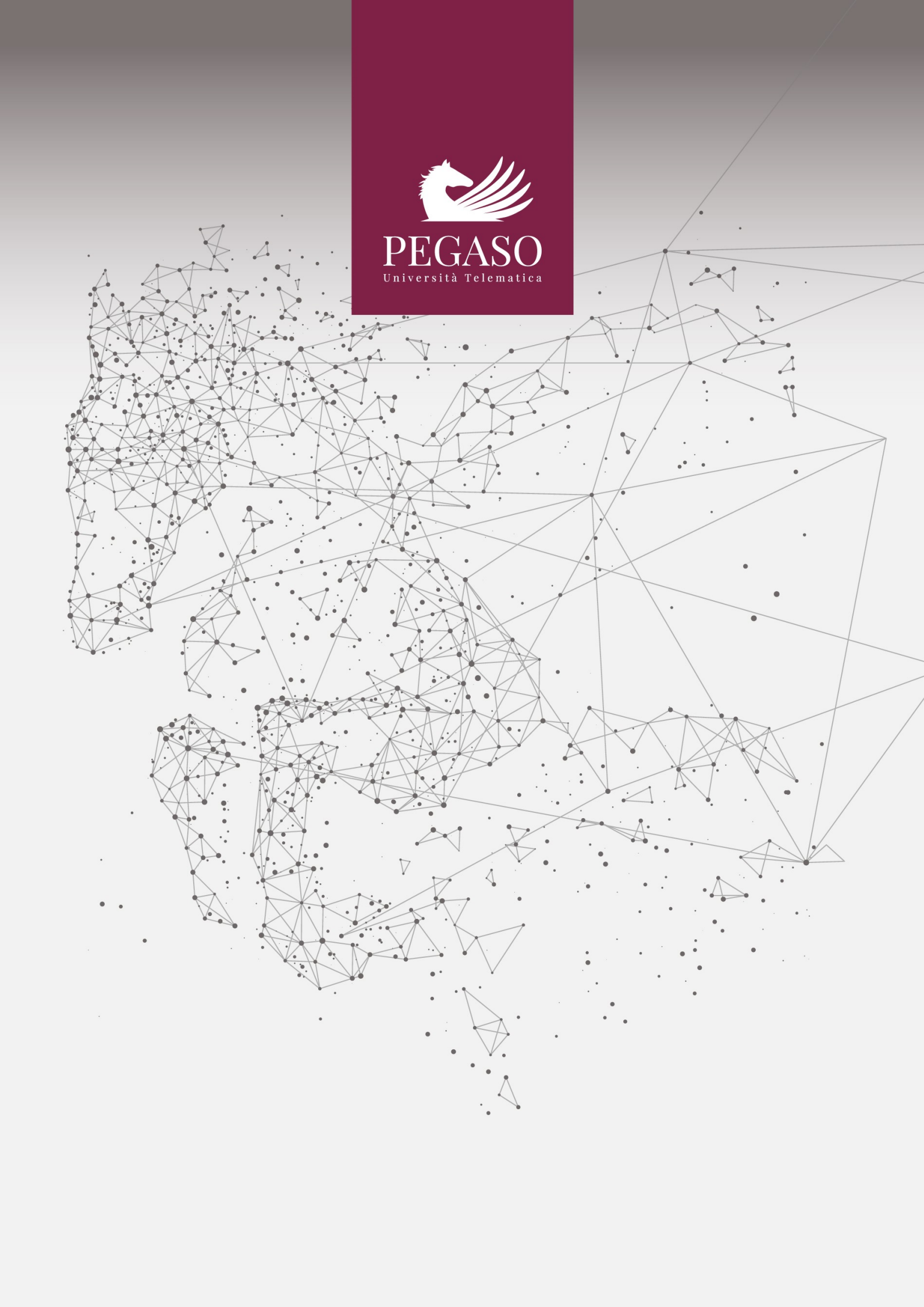

PEGASO
Università Telematica

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

Indice

1 COS'È IL REGISTRO DEI TRATTAMENTI? 3

2 CHI DEVE REDIGERE IL REGISTRO? 9

3 IL REGISTRO DEL RESPONSABILE 12

BIBLIOGRAFIA 14

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

1 Cos'è il registro dei trattamenti?

Il registro dei trattamenti è un documento contenente le principali informazioni relative alle operazioni di trattamento svolte dal titolare e, se nominato, dal responsabile del trattamento.

È previsto dall'articolo 30 del Regolamento UE 679/2016 (GDPR), rubricato "Registri delle attività di trattamento":

1. Ogni titolare del trattamento e, ove applicabile, il suo rappresentante tengono un registro delle attività di trattamento svolte sotto la propria responsabilità. Tale registro contiene tutte le seguenti informazioni:

a) il nome e i dati di contatto del titolare del trattamento e, ove applicabile, del contitolare del trattamento, del rappresentante del titolare del trattamento e del responsabile della protezione dei dati;

b) le finalità del trattamento;

c) una descrizione delle categorie di interessati e delle categorie di dati personali;

d) le categorie di destinatari a cui i dati personali sono stati o saranno comunicati, compresi i destinatari di paesi terzi od organizzazioni internazionali;

e) ove applicabile, i trasferimenti di dati personali verso un paese terzo o un'organizzazione internazionale, compresa l'identificazione del paese terzo o dell'organizzazione internazionale e, per i trasferimenti di cui al secondo comma dell'articolo 49, la documentazione delle garanzie adeguate;

f) ove possibile, i termini ultimi previsti per la cancellazione delle diverse categorie di dati;

g) ove possibile, una descrizione generale delle misure di sicurezza tecniche e organizzative di cui all'articolo 32, paragrafo 1.

PEGASO
Università Telematica

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

2. Ogni responsabile del trattamento e, ove applicabile, il suo rappresentante tengono un registro di tutte le categorie di attività relative al trattamento svolte per conto di un titolare del trattamento, contenente:

a) il nome e i dati di contatto del responsabile o dei responsabili del trattamento, di ogni titolare del trattamento per conto del quale agisce il responsabile del trattamento, del rappresentante del titolare del trattamento o del responsabile del trattamento e, ove applicabile, del responsabile della protezione dei dati;

b) le categorie dei trattamenti effettuati per conto di ogni titolare del trattamento;

c) ove applicabile, i trasferimenti di dati personali verso un paese terzo o un'organizzazione internazionale, compresa l'identificazione del paese terzo o dell'organizzazione internazionale e, per i trasferimenti di cui al secondo comma dell'articolo 49, la documentazione delle garanzie adeguate;

d) ove possibile, una descrizione generale delle misure di sicurezza tecniche e organizzative di cui all'articolo 32, paragrafo 1.

3. I registri di cui ai paragrafi 1 e 2 sono tenuti in forma scritta, anche in formato elettronico.

4. Su richiesta, il titolare del trattamento o il responsabile del trattamento e, ove applicabile, il rappresentante del titolare del trattamento o del responsabile del trattamento mettono il registro a disposizione dell'autorità di controllo.

5. Gli obblighi di cui ai paragrafi 1 e 2 non si applicano alle imprese o organizzazioni con meno di 250 dipendenti, a meno che il trattamento che esse effettuano possa presentare un rischio per i diritti e le libertà dell'interessato, il trattamento non sia occasionale o includa il trattamento di categorie particolari di dati di cui all'articolo 9, paragrafo 1, o i dati personali relativi a condanne penali e a reati di cui all'articolo 10.

PEGASO
Università Telematica

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

Si tratta di un adempimento del titolare e del responsabile del trattamento volto ad assicurare il rispetto del principio di responsabilizzazione (*accountability*): attraverso il registro, infatti, il titolare è in grado di rendicontare la propria attività, sottoponendola al contempo a una rigida organizzazione. Inoltre, attraverso il registro è possibile fare un quadro completo e aggiornato di tutti i trattamenti in essere, cosa che assicura anche la trasparenza delle operazioni di titolare e responsabile.

Per il registro è prevista dal GDPR la forma scritta, ma può essere redatto anche in formato elettronico.

In questo senso il Garante per la protezione dei dati personali, nelle FAQ sul registro delle attività di trattamento, specifica che:

"*Il Registro può essere compilato sia in formato cartaceo che elettronico ma deve in ogni caso recare, in maniera verificabile, la data della sua prima istituzione (o la data della prima creazione di ogni singola scheda per tipologia di trattamento) unitamente a quella dell'ultimo aggiornamento. In quest'ultimo caso il Registro dovrà recare una annotazione del tipo:*

"*- scheda creata in data XY*"

"*- ultimo aggiornamento avvenuto in data XY*""

Il registro deve essere esibito su richiesta del Garante per la protezione dei dati personali; sul sito dell'Autorità, nella pagina dedicata all'" Approccio basato sul rischio e misure di accountability (responsabilizzazione) di titolari e responsabili", si trova infatti la seguente raccomandazione:

> "*La tenuta del registro dei trattamenti non costituisce un adempimento formale bensì parte integrante di un sistema di corretta gestione dei dati personali. Per tale motivo, si invitano tutti i titolari di trattamento e i responsabili, a prescindere dalle dimensioni dell'organizzazione, a compiere i passi necessari per dotarsi di tale registro e, in ogni caso, a compiere un'accurata ricognizione dei trattamenti svolti e delle rispettive caratteristiche –*

PEGASO
Università Telematica

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

ove già non condotta. I contenuti del registro sono fissati, come detto, nell'art. 30; tuttavia, niente vieta a un titolare o responsabile di inserire ulteriori informazioni se lo si riterrà opportuno proprio nell'ottica della complessiva valutazione di impatto dei trattamenti svolti."

Per quanto riguarda i contenuti del registro, è necessario far riferimento all'elenco contenuto nell'articolo 30, fermo restando che titolare e responsabile possono inserire anche ulteriori informazioni, come specificato anche dal Garante. In ogni caso, i contenuti minimi del registro sono:

a) Nomi e dati di contatto del titolare, dei contitolari, del rappresentante del titolare e del DPO.

b) Le finalità del trattamento, tra le quali oltre all'indicazione delle finalità / scopi del trattamento, distinte per tipologie di trattamento, è opportuno indicare anche la base giuridica dello stesso. In caso di trattamenti di "categorie particolari di dati", è opportuno indicare una delle condizioni di cui all'articolo 9, paragrafo 2 del GDPR; in caso di trattamenti di dati relativi a condanne penali e reati, riportare la specifica normativa che ne autorizza il trattamento ai sensi dell'articolo 10 del GDPR.

c) La descrizione delle categorie di interessati, tramite la quale il titolare può evidenziare la presenza di soggetti particolarmente vulnerabili come minori, lavoratori, rifugiati, disabili, sottoposti a misure di privazione della libertà, beneficiari di provvidenze, pazienti, individui distinguibili per credo, etnia o convinzioni politiche o filosofiche; inoltre, il titolare deve anche indicare le categorie di dati personali trattati.

d) Le categorie di destinatari cui i dati sono o saranno comunicati; è inoltre opportuno che siano indicati anche gli eventuali altri soggetti ai quali – in qualità di responsabili e sub-responsabili del trattamento– siano trasmessi i dati da parte del titolare.

e) Nei casi in cui i dati siano trasferiti verso un Paese terzo o un'organizzazione internazionale, l'indicazione di questi e delle garanzie adeguate per il trasferimento, adottate ai sensi della normativa del GDPR sui trasferimenti internazionali di dati (ad

PEGASO
Università Telematica

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

esempio decisione di adeguatezza, norme vincolanti d'impresa, clausole contrattuali standard).

f) Quando sia possibile, dovranno essere indicati anche i termini ultimi previsti per la cancellazione dei dati; in questo senso, potrebbe essere utile che il titolare o il responsabile, indicando il periodo di conservazione, facciano riferimento ai criteri utilizzati per determinarlo. Non è sempre necessario che sia specificato un giorno preciso per la cancellazione, ma si può ancorare a un determinato evento, come la fine di una procedura per la quale era necessario il trattamento. È fondamentale, infatti, tenere presente il principio di limitazione della conservazione, in base al quale i dati personali devono essere conservati per un periodo non superiore a quello necessario per raggiungere le finalità del trattamento.

g) Infine, nel registro dovrebbero essere indicate, se possibile, le misure di sicurezza adottate, con una descrizione delle stesse; si tratta delle misure tecnico-organizzative che devono essere messe in piedi dal titolare ai sensi dell'articolo 32 del GDPR.

Come si è anticipato, può essere riportata nel registro qualsiasi altra informazione che il titolare o il responsabile ritengano utile indicare, come, ad esempio, le modalità di raccolta del consenso, le eventuali valutazioni di impatto effettuate, l'indicazione di eventuali "referenti interni" individuati dal titolare in merito ad alcune tipologie di trattamento ecc…

Sul sito del Garante per la protezione dei dati personali è possibile scaricare un modello di registro semplificato per le attività di trattamento del titolare per PMI. Basandosi su tale modello, si può fare una tabella esemplificativa del seguente tenore:

SCHEDA REGISTRO DEI TRATTAMENTI
Titolare/contitolare/rappresentante del titolare *[inserire la denominazione e i dati di contatto]*
Responsabile della protezione dei dati *[inserire la denominazione e i dati di contatto]*

PEGASO Università Telematica

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

Tipologia del trattamento	Finalità e basi legali del trattamento	Categorie di interessati	Categorie di dati personali	Categorie di destinatari	Trasferimento dati verso Paesi terzi o organizzazioni internazionali	Termini ultimi di cancellazione previsti	Misure di sicurezza tecniche e organizzative

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

2 Chi deve redigere il registro?

Sono obbligati alla tenuta del registro dei trattamenti:

- Imprese o organizzazioni con almeno 250 dipendenti;
- qualunque titolare o responsabile (incluse imprese o organizzazioni con meno di 250 dipendenti) che effettui trattamenti che possano presentare un rischio – anche non elevato – per i diritti e le libertà dell'interessato;
- qualunque titolare o responsabile (incluse imprese o organizzazioni con meno di 250 dipendenti) che effettui trattamenti non occasionali;
- qualunque titolare o responsabile (incluse imprese o organizzazioni con meno di 250 dipendenti) che effettui trattamenti delle categorie particolari di dati di cui all'articolo 9, paragrafo 1 GDPR, o di dati personali relativi a condanne penali e a reati di cui all'articolo 10 GDPR.

Nelle FAQ del Garante per la protezione dei dati personali relative al registro dei trattamenti, l'Autorità ha precisato che:

"*Rientrano nella categoria delle "organizzazioni" di cui all'art. 30, par. 5 anche le associazioni, fondazioni e i comitati.*

Alla luce di quanto detto sopra, sono tenuti all'obbligo di redazione del registro, ad esempio:

- esercizi commerciali, esercizi pubblici o artigiani con almeno un dipendente (bar, ristoranti, officine, negozi, piccola distribuzione, ecc.) e/o che trattino dati sanitari dei clienti (es. parrucchieri, estetisti, ottici, odontotecnici, tatuatori ecc.);

- liberi professionisti con almeno un dipendente e/o che trattino dati sanitari e/o dati relativi a condanne penali o reati (es. commercialisti, notai, avvocati, osteopati, fisioterapisti, farmacisti, medici in generale);

PEGASO
Università Telematica

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

- associazioni, fondazioni e comitati ove trattino "categorie particolari di dati" e/o dati relativi a condanne penali o reati (i.e. organizzazioni di tendenza; associazioni a tutela di soggetti c.d. "vulnerabili" quali ad esempio malati, persone con disabilità, ex detenuti ecc.; associazioni che perseguono finalità di prevenzione e contrasto delle discriminazioni di genere, razziali, basate sull'orientamento sessuale, politico o religioso ecc.; associazioni sportive con riferimento ai dati sanitari trattati; partiti e movimenti politici; sindacati; associazioni e movimenti a carattere religioso);

- il condominio ove tratti "categorie particolari di dati" (es. delibere per interventi volti al superamento e all'abbattimento delle barriere architettoniche ai sensi della L. n. 13/1989; richieste di risarcimento danni comprensive di spese mediche relativi a sinistri avvenuti all'interno dei locali condominiali).

Infine, si precisa che le imprese e organizzazioni con meno di 250 dipendenti obbligate alla tenuta del registro potranno comunque beneficiare di alcune misure di semplificazione, potendo circoscrivere l'obbligo di redazione del registro alle sole specifiche attività di trattamento sopra individuate (es. ove il trattamento delle categorie particolari di dati si riferisca a quelli inerenti un solo lavoratore dipendente, il registro potrà essere predisposto e mantenuto esclusivamente con riferimento a tale limitata tipologia di trattamento).

Al di fuori dei casi di tenuta obbligatoria del Registro, anche alla luce del considerando 82 del RGPD, il Garante ne raccomanda la redazione a tutti i titolari e responsabili del trattamento, in quanto strumento che, fornendo piena contezza del tipo di trattamenti svolti, contribuisce a meglio attuare, con modalità semplici e accessibili a tutti, il principio di accountability e, al contempo, ad agevolare in maniera dialogante e collaborativa l'attività di controllo del Garante stesso."

Per quanto riguarda le imprese con meno di 250 dipendenti, non si applicano quindi le disposizioni dei paragrafi 1 e 2 dell'articolo 30 del GDPR a meno che queste eseguano dei trattamenti che:

- Presentino un rischio per i diritti e le libertà dell'interessato;

PEGASO
Università Telematica

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

- Non siano occasionali;
- Includano dati particolari ex articolo 9 del GDPR;
- Includano dati personali relativi a condanne penali e reati ex articolo 10 del GDPR.

Le imprese e organizzazioni con meno di 250 dipendenti comunque obbligate alla tenuta del registro potranno beneficiare di alcune misure di semplificazione: è possibile circoscrivere l'obbligo di redazione del registro alle sole specifiche attività di trattamento individuate.

PEGASO
Università Telematica

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

3 Il registro del responsabile

Il responsabile del trattamento deve tenere un registro di tutte le categorie di attività relative al trattamento svolte per conto di un titolare (articolo 30 paragrafo 2 del GDPR).

Lo stesso soggetto può trovarsi a ricoprire contemporaneamente il ruolo di titolare e di responsabile per diverse attività di trattamento. In questi casi, vi sarà una situazione di doppio registro:

1. Registro come titolare, che deve tenere sempre e in ogni caso;
2. Registro come responsabile, che deve tenere eventualmente a seconda delle attività svolte.

Nel caso in cui uno stesso soggetto agisca in qualità di responsabile del trattamento per conto di più clienti quali autonomi e distinti titolari (es. società di software house), le informazioni di cui all'articolo 30, paragrafo 2 del GDPR dovranno essere riportate nel registro con riferimento a ciascuno dei suddetti titolari.

In questi casi il responsabile dovrà suddividere il registro in tante sezioni quanti sono i titolari per conto dei quali agisce.

Con riferimento alla "descrizione delle categorie di trattamenti effettuati" (articolo 30, paragrafo 2, lettera b) del GDPR) è possibile far riferimento a quanto contenuto nel contratto di designazione a responsabile che, ai sensi dell'articolo 28 del GDPR, deve individuare, in particolare:

- la natura e la finalità del trattamento,
- il tipo di dati personali e le categorie di interessati oggetto del trattamento, nonché
- la durata di quest'ultimo.

PEGASO
Università Telematica

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

Nel caso in cui vi sia un sub-responsabile, il registro delle attività di trattamento svolte da quest'ultimo potrà specificatamente far riferimento ai contenuti del contratto stipulato tra lo stesso e il responsabile ai sensi dell'articolo 28, paragrafi 2 e 4 del GDPR.

Anche per quanto riguarda il registro del responsabile del trattamento, sul sito del Garante per la protezione dei dati personali si trova un modello di "registro semplificato" delle attività di trattamento del responsabile per PMI; da tale modello si può ricavare la seguente tabella esemplificativa:

SCHEDA REGISTRO DEI TRATTAMENTI DEL RESPONSABILE/SUB-RESPONSABILE		
Responsabile *[inserire la denominazione e i dati di contatto]*		
Titolare/contitolare/rappresentante del titolare *[inserire la denominazione e i dati di contatto]*		
Responsabile della protezione dei dati *[inserire la denominazione e i dati di contatto]*		
Categoria di trattamento	Trasferimento di dati verso Paesi terzi e organizzazioni internazionali	Misure di sicurezza tecniche e organizzative

.

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

Bibliografia

- Garante per la protezione dei dati personali, FAQ sul registro delle attività di trattamento
- Garante per la protezione dei dati personali, Approccio basato sul rischio e misure di accountability (responsabilizzazione) di titolari e responsabili
- Garante per la protezione dei dati personali, Modello di "registro semplificato" delle attività di trattamento del titolare per PMI (ALLEGATO 1)
- Garante per la protezione dei dati personali, Modello di "registro semplificato" delle attività di trattamento del responsabile per PMI (ALLEGATO 2)

PEGASO
Università Telematica

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).